

TP2

Exercice 1

- 1) Installer Docker si ce n'est pas fait : <https://www.kali.org/docs/containers/installing-docker-on-kali/>
- 2) Créer un dossier tp2_exo1 puis récupérer et décompresser les fichiers tp2_exercice1.zip dedans.
- 3) Exécuter les 3 commandes suivantes :

```
sudo docker network create --subnet=172.16.5.0/24 mynetwork_vuln  
sudo docker build -t exo1 .  
sudo docker run -d --network mynetwork_vuln --ip 172.16.5.10 exo1
```

- 4) Utiliser un navigateur web pour aller sur <http://172.16.5.10:8888/> et intercepter les requêtes HTTP avec Burp Suite.

Q1 : Quel est le langage utilisé côté serveur ?

Q2 : Quelle est la version du serveur ainsi que la version de sa bibliothèque mentionnée ?

Q3 : Combien de CVE existent pour cette version ?

Q4 : Quelle est la CVE en 2024 qui a le niveau de risque le plus élevé ?

Q5 : Exploiter cette vulnérabilité pour récupérer le fichier /secrets.txt et son flag.

Exercice 2

- 1) Récupérer et décompresser les fichiers dans tp2_exercice2.zip
- 2) Exécuter les 2 commandes suivantes :

```
sudo docker build -t exo2 .  
sudo docker run -d --network mynetwork_vuln --ip 172.16.5.14 exo2
```

Q1 : Avec Nmap, scanner l'adresse 172.16.5.14, combien de ports sont ouverts ?

Q2 : Quel service est accessible sans mot de passe ?

Q3 : Récupérer le fichier accessible. Quel est le nom d'utilisateur donné ?

Q4 : En connaissant ce nom d'utilisateur, faire du brute-force avec Hydra sur le service FTP et avec la liste de mots de passe /usr/share/wordlists/rockyou.txt. Trouver le mot de passe de cet utilisateur.

Q5 : Se connecter sur FTP avec le compte trouvé. Quel est le flag ?

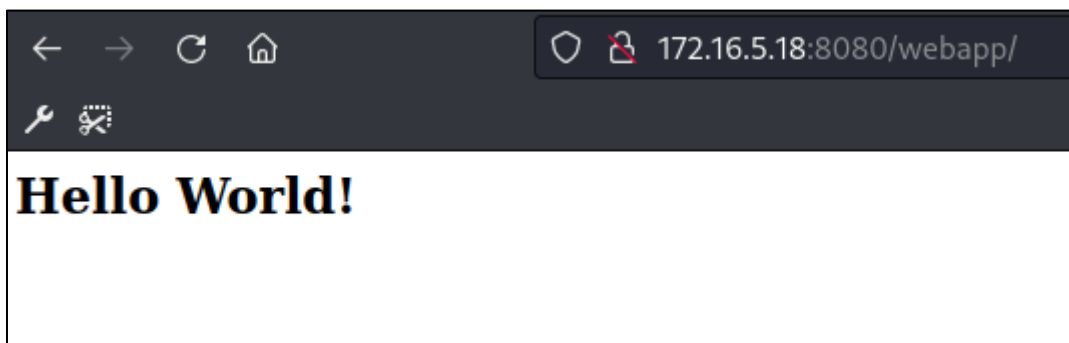
Exercice 3

- 1) Récupérer et décompresser les fichiers dans tp2_exercice3.zip
- 2) Exécuter les 2 commandes suivantes :

```
sudo docker build -t exo3 .
```

```
sudo docker run --network mynetwork_vuln --ip 172.16.5.18 exo3
```

Accédez à <http://172.16.5.18:8080/webapp/> vous devriez voir ceci :



Q1 : Quelle est la technologie et le langage utilisés dans cette application ?

Q2 : Quelle est sa version ?

Q3 : Quelle est sa page d'administration (par défaut) ?

Q4 : Donner le login et mot de passe par défaut qui fonctionne ici.

Q5 : Se connecter et déployer un fichier contenant un payload qui permettra de récupérer un reverse shell. Pour créer le fichier avec le payload, utiliser l'outil msfvenom avec les bons paramètres ensuite uploader et déployer le fichier dans l'interface.

Docker :

Pour arrêter un conteneur démarré avec l'option « -d » (daemon), il faut lister les conteneurs :

```
sudo docker ps -a
```

```
<id> mon_conteneur
```

Et récupérer l'identifiant du conteneur à arrêter (les conteneurs démarrés sont ont leur STATUS à « Up »).

Ensuite, l'arrêter simplement avec la commande stop :

```
sudo docker stop <id>
```